

PROMOTION 2026-2027

Detection Engineering pour un SOC

Windows / Active Directory — SIEM — MITRE ATT&CK

Projet FYC — Find Your Course

Quatre étudiants, un mentor professionnel, un cours à transmettre.

Le mentor n'est pas un évaluateur passif : il aide à délimiter le sujet, valide la scénarisation et suit la production jusqu'à la soutenance.

Victor TASSART

Marwane ZAID

Younès HANNOUR

Jacques-D'evaldo TOBOSSOU

MENTOR

Adam RAHMI

Professionnel du sujet, partie prenante du suivi.

Chacun contribue à l'ensemble du cours. Un responsable clair est désigné par livrable.

Former à concevoir, tester et évaluer des détections SOC sur Windows / Active Directory.

Le cours transmet une méthode reproductible, pas seulement une démonstration d'outil. Le lab et les règles sont le support. Le savoir réutilisable est le cœur.

- Expliquer le rôle d'un SOC et d'un SIEM dans la détection.
- Relier une alerte à une technique MITRE ATT&CK.
- Appliquer une méthode simple pour créer une détection.
- Distinguer un IOC faible et une détection de comportement (TTP).
- Proposer un triage Tier 1 et critiquer une règle (bruit, couverture, limites).

Un SOC reçoit beaucoup d'alertes. Une grande partie sont des faux positifs.

Comment concevoir, valider et transmettre une démarche de detection engineering pour Windows / Active Directory, qui améliore la pertinence des alertes SIEM tout en maîtrisant les faux positifs ?

■ **Le point de départ**

Trop d'alertes, trop peu de méthode pour les écrire et les trier.

■ **La réponse du cours**

Une méthode en 8 étapes, trois cas Windows / AD, un triage Tier 1 documenté.

■ **Ce que l'apprenant repart avec**

Un cadre, un catalogue mappé ATT&CK, une SOP de triage, des limites assumées.

L'originalité est dans la formulation : passer de « la cybersécurité » à une méthode opérationnelle de detection engineering, enseignable en Mastère 1.

■ Ce que le cours est

Un cours que l'on aurait aimé avoir : écrire une détection, la tester, la tuner.
De niveau 1re année de Mastère, sur une thématique que le groupe porte.
Original par l'angle : Windows / AD, SIEM, ATT&CK, faux positifs.

■ Ce que le cours n'est pas

Un TP dont le seul but est de faire démarrer un SIEM.
Un cours déjà suivi en B3 ou en M1, ni « l'IA » sans angle.
Une couverture complète d'ATT&CK, du cloud ou du forensic.

Niveau visé : informatique, bac+3 à bac+4 (systèmes, réseaux, cybersécurité).

Aucune connaissance préalable en SOC ou en SIEM. L'exercice 1 sert de prise en main Git et Docker.

■ Réseaux

TCP/IP, ports, protocoles courants.

■ Windows et Active Directory

Utilisateurs, groupes, authentification.

■ Ligne de commande

Suffisante pour lancer un lab et lire un log.

■ Git et Docker

Notions de base. Le premier exercice les remet en main.

Le sujet tient parce qu'il est borné. Le mentor valide cette frontière en séance 1.

Inclus	Hors périmètre
Windows et Active Directory	Environnements multi-cloud
Un SIEM en lab Docker	Couverture complète d'ATT&CK
3 cas pratiques commentés	SOAR et threat hunting
Triage Tier 1	Forensic approfondi
Mini-rapport d'incident	Réponse à incident complète

15 vidéos prévues. Si le temps manque, les cas V9 à V11 fusionnent en 2 vidéos (13 au total). SIEM proposé : Wazuh, simple à lancer avec Docker. Elastic reste possible selon l'avis du mentor.

Le cours

On apprend en regardant, en lisant, puis en faisant. Durée pour l'apprenant : 10 à 15 h.

1**Théorie**

SOC, SIEM, ATT&CK

2**Méthode**

8 étapes, une règle

3**Cas**

4625, LSASS, RDP

4**Transfert**

Triage et rapport

- Vidéo de présentation de l'équipe, 3 min maximum, puis 13 à 15 vidéos de 8 min.
- Poly de 40 pages ± 2 : la même matière, écrite, illustrée, réutilisable.
- 3 exercices Docker / GitHub avec corrigés, puis un examen final avec corrigé.

Chaque vidéo dure 8 minutes maximum et est sous-titrée. V0 dure 3 minutes.

	Titre	Ce que l'apprenant retient
V0	Présentation du cours	Équipe, public, problème, parcours
V1	Qu'est-ce qu'un SOC ?	Tiers, cycle de vie d'une alerte
V2	SIEM	Collecter, corrélér, TTD / TTR
V3	MITRE ATT&CK	Tactique, technique, sous-technique
V4	Kill Chain et Pyramid of Pain	Détecter un TTP plutôt qu'une IP
V5	Logs Windows	4624, 4625, 4688, 4732, 7045
V6	Sysmon	Télémétrie endpoint, accès LSASS
V7	Méthode	Les 8 étapes, cœur du cours

Les cas appliquent la méthode. Le triage et le rapport la rendent professionnelle.

	Titre	Ce que l'apprenant retient
V8	Écrire une règle	Anatomie Sigma / SIEM, GitHub
V9	Brute force 4625	T1110, alerte, vrai brute vs mot de passe
V10	LSASS	T1003.001, ProcessAccess, cadre lab
V11	RDP et comptes à risque	Logon type 10, compte désactivé
V12	Tuning et faux positifs	FP / FN, seuils, mesure avant / après
V13	Triage Tier 1	Nothing, Consult, Escalate + SOP
V14	Rapport d'incident	Résumé, timeline, IoC, recommandations
V15	Synthèse	Checklist, limites, suite possible

C'est le fil du cours. La même grille revient dans les vidéos, le poly et les exercices.

1 Choisir une technique ATT&CK

2 Formuler une hypothèse

3 Identifier les logs

4 Écrire la règle

5 Simuler, de façon contrôlée

6 Vérifier l'alerte

7 Analyser les faux positifs

8 Tuner, documenter, écrire la SOP

Retranscription illustrée des vidéos : schémas, tableaux, captures, exemples de règles.

Règle d'équipe : une vidéo validée, sa section de poly rédigée dans les 7 jours. Rien n'attend janvier.

Chapitre	Pages	Vidéos	Contenu
Intro et objectifs	2	V0	Public, prérequis, plan
SOC et SIEM	6	V1–V2	Définitions, métriques
ATT&CK, Kill Chain, PoP	6	V3–V4	Exemples et figures
Logs Windows et Sysmon	6	V5–V6	Aide-mémoire Event IDs
Méthode et règles	7	V7–V8	8 étapes, anatomie
Trois cas	7	V9–V11	Hypothèse, règle, triage
Tuning, triage, rapport	7	V12–V15	SOP, template, synthèse

Reproductibles sur une machine neuve. Corrigé et barème joints à chaque exercice.

01**Lab Docker + GitHub**

Cloner, lancer docker compose, vérifier les événements, déposer une capture.

02**Règle versionnée**

Choisir une technique, remplir la fiche, écrire la règle, pousser une branche.

03**Alerte et triage**

Lancer le scénario, trouver l'alerte, décider Nothing / Consult / Escalate.

60 à 90 minutes. Sujet, corrigé détaillé et barème sont déposés avec le cours.

Partie	Poids	Ce qu'on vérifie
A — QCM	30 %	SOC, SIEM, ATT&CK, Event IDs, FP / TP
B — Mapping	25 %	Un log vers une technique, avec justification
C — Conception	25 %	Hypothèse, logs, ébauche de règle, FP
D — Triage	20 %	Décision et 5 à 8 lignes de justification

Moodle fait foi pour la date et pour la consultation par le jury.

- Vidéo de présentation (3 min) et texte d'accroche.
- Bibliographie commentée : MITRE, Microsoft, Sigma, ANSSI.
- 13 à 15 vidéos sous-titrées, et le poly de 40 pages $\pm$ 2.
- 3 exercices Docker / GitHub avec corrigés.
- Examen final avec corrigé.
- Dépôt GitHub : videos, poly, rules, exercices, exam, docker.

La production

Un responsable par livrable. Le suivi ESGI reste individuel : chacun touche à tout.

Responsable	Porte
Pédagogie	Scénarisation, prérequis, cohérence, rapports de séance
Théorie / poly	Chapitres 1 à 4, bibliographie, glossaire
Labs	Docker, GitHub, exercices, corrigés, démos
Forme	Tournage, sous-titres, accroche, examen

Une vidéo est finie quand le script est relu, la durée tient en 8 min, les sous-titres sont faits et la section de poly correspondante existe, au moins en brouillon.

Quatre séances. Entre chacune, le groupe produit et remet un rapport sous 48 h.

Jalons	Période	Objectif
Séance 1 — cadrage	7 sept. → 1 oct.	Sujet, scénario v1, biblio
Séance 2 — scénario	1 oct. → 1 nov.	Validation, démo ~30 %
Séance 3 — mi-parcours	1 nov. → 1 déc.	Démo ~50 %, qualité
Séance 4 — final	1 déc. → 10 janv.	Cours complet, corrections
Dépôt Moodle	17 janv. 2027, 23h59	Date provisoire
Soutenance	Février 2027	30 min + 25 min de questions

Première rencontre avec Adam Rahmi. On pose le sujet, on ne produit pas encore le cours.

■ **On présente**

Sujet, prérequis, scénarisation v1, bibliographie initiale.

■ **On décide avec le mentor**

Périmètre exact, 13 ou 15 vidéos.

Stack SIEM : Wazuh ou Elastic.

Niveau réel des prérequis.

■ **On livre sous 48 h**

Ce rapport, sur Moodle, au responsable pédagogique et au mentor.

La séance 2 fige le sujet. On arrive avec environ 30 % du cours montrable.

- **Figurer le plan des vidéos et la scénarisation finale.**
- **Tourner V1 à V4 : SOC, SIEM, ATT&CK, Kill Chain.**
- **Ouvrir le dépôt GitHub et un premier lab Docker.**
- **Rédiger les chapitres 1 et 2 du poly.**
- **Préparer la démo : vidéos, début de poly, ébauche de l'exercice 1.**

Les sources de départ. La liste commentée complète ira sur Moodle avec le cours.

■ **MITRE ATT&CK — attack.mitre.org**

Tactiques, techniques, sous-techniques, mapping des alertes.

■ **Microsoft**

Événements de sécurité Windows et documentation Sysmon.

■ **Sigma**

Format de règles de détection, versionnable, partageable.

■ **ANSSI**

Guides de journalisation et de détection.

■ **Références de forme**

SecNumAcadémie, OpenClassrooms, pour la structure d'un cours.

Février 2027. 60 minutes. On défend le cours comme un produit, pas comme un exposé.

Temps	Contenu
30 min	Pourquoi ce cours, objectifs, scénario, extrait vidéo, démo Docker
25 min	Questions du jury et du mentor
5 min	Délibération

- **Note finale supérieure à 10, obligatoire pour le Mastère.**
- **Suivi 40 % · Livrables 40 % · Soutenance 20 %.**
- **Bonus ou malus individuel de ± 10 points, selon l'apport de chacun.**

Vidéos	On enseigne à l'oral, module par module.
Poly	On écrit la même chose, plus détaillée et illustrée.
Exercices	L'apprenant fait : Docker, règle, triage.
Examen	On vérifie qu'il a compris.
Séances	Le mentor valide et corrige le cap.
Soutenance	On vend le cours au jury.